CONDITIONAL ACCESS · MFA · SSO · AI AGENTS

Who signs in?



130 cases on made-up data. Every guess written,
hashed and committed before any code ran.
Six of them were wrong.

130
cases

124
run on models

6
wrong guesses

7
links in the chain

Roshan Trivedi

Edition 1, 14 November 2026 · roshantrivedi.co.in/ca-mfa-lab/ · CC BY 4.0

Independent work on my own time. Nothing here describes any employer's or client's systems.

How to read this book

This is the long version of a public lab I ran on conditional access, MFA, 2FA, single sign-on and AI agent identity. If you have five minutes, read the short version on the next page and chapter 3. If you have an afternoon, read the link chapters for the parts of sign-in you own.

Everything here runs on made-up data for a made-up company. A case is a small rule model written in Python. It shows whether my reasoning about a control holds together. It does not show how any vendor's product behaves, and nothing in it describes any employer's or client's systems.

Throughout the book, red means the bad outcome happens and green means it is stopped. Each of the seven links in the framework has its own colour, and the band at the top of each page shows which link you are reading.

> **The rule that holds the book together**
> For every case I wrote my guess first, saved it, took its SHA-256 hash and committed it before a line of the model existed. A guess file cannot be changed later without its hash changing. When a guess was wrong, it stays in the book as wrong.

Contents

The short version 4

1. The problem 5

- Who this is for 5
- What is new since the first runs 5

2. Scope and method 6

- In scope 6
- Out of scope 6
- How a case was run 6
- The six runs 7

3. The framework: the access chain 8

4. Enrol and recover 10

5. Prove 15

6. Trust 19

7. Decide 26

8. Issue 35

9. Act 41

10. Watch and end 46

11. What I got wrong . . . 51

One mistake in my own code . . . 51

12. What changes the answer . . . 52

13. What companies are suffering . . . 53

14. Research and development: where vendors and standards are going . . . 55

15. The lab for your people . . . 57

Run the scripts . . . 57

The six hand tests . . . 57

Report an exception . . . 57

Run it as a team workshop . . . 57

16. Conclusion . . . 59

Appendix A: Evidence . . . 60

Guess files . . . 60

Reproduction . . . 60

Assumptions in Runs 5 and 6 . . . 61

Appendix B: The full register . . . 62

Appendix C: Glossary . . . 68

Appendix D: Sources . . . 70

Standards and documents . . . 70

Events . . . 71

READ THIS IF YOU READ NOTHING ELSE

The short version

130
cases in the register

124
run on small models

118
guesses matched

6
guesses wrong, all in one run

I ran 124 of the 130 cases. 118 matched the guess I had locked before any code. Six did not, and all six were in Run 2, the run where each case had two or three controls working together.

The score is the least useful result. Four things I would tell a team that owns sign-in:

1. MFA was often not the control that decided the outcome. A stolen integration token never triggers a sign-in. A password reset that does not kill refresh tokens leaves a stolen session alive. A recovery path weaker than sign-in lets an attacker enrol their own authenticator.
2. The largest group of cases sits in link 4, Decide: a rule that does not cover the sign-in, an exception that grew, a legacy protocol that skips MFA. It holds 33 of the 130 cases and 3 of my 6 wrong guesses.
3. For AI agents, the controls that decided Run 6 were plain ones: a named human owner, an identity that expires with the task, and a check at the resource against the human's own rights. Narrowing a sub-agent's token and rotating its credential did not decide anything.
4. Each result rests on an assumption I chose. When I changed one assumption at a time, results flipped. A pass in this book holds only while its assumption holds.

Six cases need a real tenant, a hardware key, a real agent product or a person on the phone. They are written up as hand tests for anyone to run, with my predictions locked.

WHY SIGN-IN STILL FAILS AFTER MFA

1 The problem

Most organisations have MFA switched on and single sign-on in front of their main apps. Attackers still get in, and the reports usually say MFA was in place. That is the gap this lab looks at.

Sign-in controls fail in two opposite ways. When a control is too hard, people route around it: an exclusion group, a legacy protocol kept for printers, a help desk that resets MFA to keep a caller happy. When it is too easy, it becomes a side door: a push prompt a tired user approves, a recovery path weaker than sign-in, a token that lives for 90 days.

A control mapping sheet tells you a control exists. It does not tell you where the control stops. I wanted to find where each one stops, and I wanted my wrong guesses on the record.

Who this is for

- People who own an identity provider, conditional access policies or SSO for apps.
- Security architects reviewing MFA, recovery or federation designs.
- Teams building AI agents that sign in, call APIs or act for people.
- Auditors who want to know what evidence would show a control works.

What is new since the first runs

The first three runs covered MFA methods, SSO protocols, recovery and policy logic. Run 5 added cases from incidents in 2025 and 2026: CI/CD cloud trust, stolen integration tokens, privileged APIs and MCP sign-in. Run 6 added AI agent identity: cross-app access, sub-agents, agents that outlive their project or lose their owner.

WHAT IS IN, WHAT IS OUT, AND HOW EACH CASE WAS RUN

2 Scope and method

In scope

- MFA and 2FA methods: SMS, TOTP, push, number matching, passkeys and security keys.
- Single sign-on: SAML, OpenID Connect and OAuth flows, federation and signing keys.
- Conditional access policy logic, context signals, exceptions and emergency accounts.
- Account recovery and help desk resets.
- Tokens: scope, lifetime, binding, refresh and revocation.
- CI/CD cloud trust, API integrations, MCP clients and servers, and AI agents acting for people.

Out of scope

- How any named product behaves. I did not test vendors.
- Real tenants, real people and real data. Six hand tests are left for readers.
- Performance, cost and user experience.

How a case was run

1. Pick a failure from the catalogue and the controls that should stop it. Write down the bad outcome first, so I know what I am counting.
2. Write the expected result with no controls, with all controls on, and with each control switched off on its own.
3. Save the guesses, hash the file with SHA-256 and commit it. Merge it before any model code exists.
4. Write the model, run it, and compare the output with the parsed guess file. The script refuses to run if the guess file's hash differs.
5. Record every miss. Fix my own coding mistakes in the open and keep the first-pass files.
6. For Runs 5 and 6, change one assumption at a time and record which results flip.

The six runs

Run	What it covered	Cases	Matched	Guess file SHA-256 (first 16)
1	Single controls: MFA methods, SSO protocols, recovery	41	41 of 41	2675a0efa8937fb5
2	Two or three controls working together	45	39 of 45	f7c8439b21cda129
3	Step-up, federation, mobile, passkeys, agents and MCP	16	16 of 16	a09daa459851a1d9
4	Hand tests E01 to E03 (predictions only)	3	not run	38f544b069739445
5	CI/CD, APIs and integrations, agents, recovery	12	12 of 12	bc344bbd00d01d16
6	AI agent identity, plus hand tests E04 to E06	10 + 3	10 of 10	1abdbf110b583755

Why the perfect runs prove little

I wrote each model after its guesses. A perfect score shows that my model and my reasoning agree. Nothing outside me tested the guesses. Run 2 was the only run that caught me out, and it taught me the most.

SEVEN LINKS EVERY SIGN-IN PASSES THROUGH

3 The framework: the access chain

Every sign-in, and every action an agent takes for a person, passes through seven links. A case belongs to the link where its deciding control sits. A weak link anywhere lets the bad outcome through, however strong MFA is at link 2.

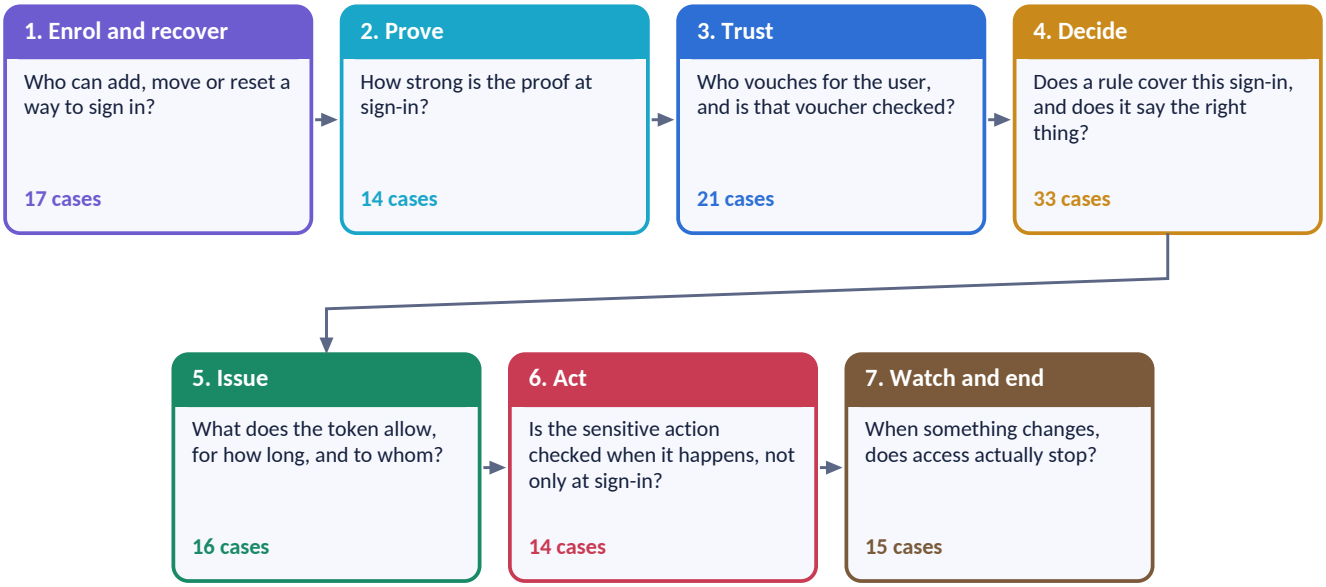


Figure 1. The access chain. Read left to right, top row then bottom row. Each box shows the question the link asks and how many cases sit in it.

Link	The question	Controls that decide it	Cases	Run	One off lets it in	Wrong
1. Enrol and recover	Who can add, move or reset a way to sign in?	Phishing-resistant enrolment, callback before reset, notice on change, delay on new methods	17	15	10	1
2. Prove	How strong is the proof at sign-in?	Phishing-resistant methods, number matching, rate limits, no weaker fallback	14	14	10	0
3. Trust	Who vouches for the user, and is that voucher checked?	Assertion replay and audience checks, exact redirects, PKCE, signing key care, pinned federation and CI/CD trust	21	21	17	0
4. Decide	Does a rule cover this sign-in, and does it say the right thing?	Default deny, no broad exceptions, report-only first, device and context signals that cannot be faked	33	32	26	3

Link	The question	Controls that decide it	Cases	Run	One off lets it in	Wrong
5. Issue	What does the token allow, for how long, and to whom?	Narrow scope, short life, binding to the client, refresh rotation and a maximum age, no stored secrets	16	16	10	1
6. Act	Is the sensitive action checked when it happens, not only at sign-in?	Step-up checked by the server, every credential type covered, actions limited to what the human named and may do	14	13	12	1
7. Watch and end	When something changes, does access actually stop?	Revocation that reaches every token, continuous evaluation, expiry with the task, a named owner, logs that name the human	15	13	9	0

Two counts stand out. Link 4, Decide, holds a quarter of the cases and half the wrong guesses. Link 6, Act, has the highest share of cases where switching off one control on its own let the bad outcome in: 12 of the 13 run.

LINK 1 OF 7

4 Enrol and recover

Who can add, move or reset a way to sign in?

17	15	10	1
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Phishing-resistant enrolment, callback before reset, notice on change, delay on new methods.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

M06 Passkey synced across devices: loss of one device

1. Enrol and recover · Run 1 · MFA methods

What I wrote first	Synced passkey, one device lost: user still signs in from another / in / n/a
Limit I expected	Synced to a compromised cloud account is not modelled

	No control	Control on	Control off alone
Output	stopped	stopped	stopped
My guess	stopped	stopped	not tested

Source: NIST SP 800-63B-4, Appendix B (syncable authenticators); FIDO Alliance (not read). Source read: Confirmed, with a qualifier.

M08 SMS kept as recovery: attacker picks the weakest allowed method

1. Enrol and recover · Run 1 · MFA methods

What I wrote first	SMS recovery allowed: attacker picks SMS and gets in / SMS removed from recovery: blocked / off: in
Limit I expected	Another weak recovery path can replace it

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

M09 SIM swap moves the SMS factor to the attacker

1. Enrol and recover · Run 1 · MFA methods

What I wrote first	SIM swap: attacker gets SMS codes / no SMS factor: blocked / off: in
Limit I expected	Swap detection is not modelled

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: NIST SP 800-63B-4. Source read: not read yet.

R01 Help desk resets MFA after a caller gives name and phone number

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	Name and phone number: MFA reset granted / strong identity proof: refused / off: granted
Limit I expected	A well-informed attacker may still pass weak proof

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

R02 Method change with no notice to the person

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	Method changed, no notice: owner never learns / notice sent: owner learns / off: silent
Limit I expected	Notice to an email the attacker also controls does not help

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

R03 Admin reset with no delay

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	Admin reset with no delay: instant / 24 hour delay with notice: owner can object / off: instant
Limit I expected	Delay only helps if someone reads the notice

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

R04 Account recovery by email to a mailbox the attacker owns

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	Recovery email owned by attacker: account taken / recovery email must be verified and old: refused / off: taken
Limit I expected	Compromised legitimate mailbox is not modelled

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: NIST SP 800-63B-4. Source read: not read yet.

R05 New device enrolment right after a password reset

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	New device enrolled right after password reset: accepted / hold new enrolment 24 hours: held / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Own catalogue. Source read: not read yet.

R06 Temporary access pass lifetime too long

1. Enrol and recover · Run 1 · Recovery and help desk

What I wrote first	Temporary access pass long lived: reused by attacker / short life, one use: refused / off: reused
Limit I expected	One short window still exists

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Vendor docs; verify. Source read: Confirmed.

Z02 Attacker registers their own MFA method after stealing the password

1. Enrol and recover · Run 1 · MFA methods

What I wrote first	Attacker registers own method after password theft: persists / registration needs existing MFA: blocked / off: persists
Limit I expected	Registration right after a password reset is the gap

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Compass Security, Entra findings part 4. Source read: Confirmed.

C01 Weak SMS fallback plus help desk reset plus no notice

1. Enrol and recover · Run 2 · Chain tests

Bad outcome	account taken and unnoticed
Controls	A remove SMS recovery, B strong help desk proof, C method-change notice

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	happens	happens	stopped

A cell with a dark outline is where my guess was wrong.

Source: Draft 4 Nov. Source read: not read yet.

C05 Passkey fallback to SMS plus SIM swap plus notice missing

1. Enrol and recover · Run 2 · Chain tests

Bad outcome	takeover via SIM swap
Controls	A remove SMS fallback, B SIM swap check, C method-change notice

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

Two controls off together (A and B): output in, I guessed in.

My reasoning when I guessed: I expect any two of A and B off together to give in

Source: Draft 4 Nov. Source read: not read yet.

Z22 Stolen password plus open security-info registration plus no device rule

1. Enrol and recover · Run 2 · Chain tests

Bad outcome	stolen password plus own MFA gets in
Controls	A registration protection, B device rule on access, C MFA required

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

Two controls off together (A and B): output in, I guessed in.

My reasoning when I guessed: I expect A and B off together to give in

Source: Compass Security. Source read: Partly confirmed.

Y09 Attacker with a stolen session registers their own passkey and keeps access after sessions are revoked

1. Enrol and recover · Run 3 · Passkeys and recovery

Bad outcome	attacker still has access 24 hours after sessions are revoked
Controls	A fresh strong sign-in to add a method, B revoke methods added since compromise, C alert on a new method

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: C is a notice but it triggers B; assume the user acts on it

Assumes: attacker has a stolen session; the user reports within the day; reporting revokes sessions; the user acts on an alert

Source: Black Swan advisory 8 Sep 2026 (excerpt). Source read: Confirmed.

E02 Real FIDO2 hardware key enrolment and loss

1. Enrol and recover · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: FIDO Alliance. Source read: not read yet.

E03 Real help desk call handling

1. Enrol and recover · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: Own catalogue. Source read: not read yet.

W12 Recovery path enrols an attacker's authenticator because it is weaker than sign-in

1. Enrol and recover · Run 5 · Recovery and help desk

Bad outcome	attacker gets a working new authenticator enrolled on the account
Controls	A self-service recovery needs a phishing-resistant method, B help desk reset needs a callback to the number on file, C a new method cannot be used on privileged apps for 24 hours

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	stopped
My guess	happens	stopped	happens	happens	stopped

My reasoning when I guessed: two paths into enrolment, A and B; C limits what the new method can do, not whether it is enrolled

Source: SC World and LevelBlue on Okta help desk vishing (Apr 2026); excerpts. Source read: not read yet.

LINK 2 OF 7

5 Prove

How strong is the proof at sign-in?

14	14	10	0
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Phishing-resistant methods, number matching, rate limits, no weaker fallback.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

M01 SMS or voice code is relayed by a phishing page in real time

2. Prove · Run 1 · MFA methods

What I wrote first	SMS code relayed live: attacker gets in / SMS kept as a factor: still gets in (relay works) / n/a
Limit I expected	Only a phishing-resistant factor stops it

	No control	Control on	Control off alone
Output	happens	happens	happens
My guess	happens	happens	happens

Source: NIST SP 800-63B-4; draft 4 Nov. Source read: not read yet.

M02 TOTP code is relayed by a phishing page inside its 30 second window

2. Prove · Run 1 · MFA methods

What I wrote first	TOTP relayed inside 30s: gets in / TOTP: still gets in / n/a
Limit I expected	Same limit as M01

	No control	Control on	Control off alone
Output	happens	happens	happens
My guess	happens	happens	happens

Source: RFC 6238. Source read: not read yet.

M03 Push approval with no number match accepted by a tired user (prompt bombing)

2. Prove · Run 1 · MFA methods

What I wrote first	Push, no number match: tired user approves, attacker in / Number matching: blocked / Off: in again
Limit I expected	A user who reads the number to the attacker still loses

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: CISA 2022 number matching. Source read: not read yet.

M04 Push with number matching: attacker cannot supply the number

2. Prove · Run 1 · MFA methods

What I wrote first	Number match: attacker cannot supply number: blocked / blocked / off: in
Limit I expected	Vishing a user into reading the number is not modelled

	No control	Control on	Control off alone
Output	stopped	stopped	happens
My guess	stopped	stopped	happens

Source: CISA 2022. Source read: not read yet.

M05 Passkey or security key on a look-alike domain: origin check refuses

2. Prove · Run 1 · MFA methods

What I wrote first	Passkey on look-alike domain: refused (origin differs) / refused / origin check off: accepted
Limit I expected	Only if the real site is not itself compromised

	No control	Control on	Control off alone
Output	stopped	stopped	happens
My guess	stopped	stopped	happens

Source: W3C WebAuthn; FIDO Alliance. Source read: not read yet.

M07 Backup codes reused after first use

2. Prove · Run 1 · MFA methods

What I wrote first	Backup code reused: accepted twice / one-time use: second refused / off: accepted twice
Limit I expected	Codes stolen before first use still work once

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Vendor docs; verify. Source read: Confirmed.

M10 TOTP seed stolen from a shared spreadsheet

2. Prove · Run 1 · MFA methods

What I wrote first	TOTP seed in shared sheet: attacker generates valid codes / seed in vault only: blocked / off: in
Limit I expected	Seed stolen at enrolment time still works

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Own catalogue. Source read: not read yet.

M11 Counter or clock drift on TOTP: allowed window too wide

2. Prove · Run 1 · MFA methods

What I wrote first	Wide TOTP window: a code from 3 steps ago accepted / 1 step window: refused / off: accepted
Limit I expected	Clock skew will refuse some real users, which I expect to record

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: RFC 6238. Source read: not read yet.

M12 Rate limit on wrong codes: 6 digit code guessed without lockout

2. Prove · Run 1 · MFA methods

What I wrote first	6-digit code, no rate limit: guessed within the run / rate limit: blocked / off: guessed
Limit I expected	Slow guessing across many accounts passes a per-account limit

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: NIST SP 800-63B-4. Source read: not read yet.

M13 Lockout used by an attacker to deny a real user

2. Prove · Run 1 · MFA methods

What I wrote first	Attacker locks real user out / lockout on: real user locked out (lockout is the attack) / off: user stays in
Limit I expected	Lockout and rate limit pull in opposite directions

	No control	Control on	Control off alone
Output	stopped	happens	stopped
My guess	not tested	happens	stopped

Source: NIST SP 800-63B-4. Source read: not read yet.

M14 Method downgrade: user chooses weaker factor at prompt

2. Prove · Run 1 · MFA methods

What I wrote first	Weaker factor offered at prompt: user picks it, attacker uses it / only strong factors allowed: blocked / off: weak accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

Z01 QR code lure (quishing) sends the user to a look-alike sign-in page

2. Prove · Run 1 · MFA methods

What I wrote first	QR lure to look-alike page: credentials and code captured / user trained: partly / phishing-resistant factor: blocked
Limit I expected	Training alone will fail some users

	No control	Control on	Control off alone
Output	happens	not tested	stopped
My guess	happens	not tested	stopped

Source: Swissbit AiTM blog; Menlo Security blog. Source read: Partly confirmed.

A01 Admin on SMS fallback: phishing-resistant rule has a weaker alternative

2. Prove · Run 2 · Privileged roles

Bad outcome	admin phished via SMS on any app
Controls	A phishing-resistant rule on admin portals only, B remove SMS from admin methods

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

Source: NIST SP 800-63B-4. Source read: not read yet.

Y08 Pass-the-passkey: malware on the endpoint gets a valid passkey assertion with little or no user action (verify)

2. Prove · Run 3 · Passkeys and recovery

Bad outcome	assertion produced with no user action (verify)
Controls	A user verification on every use, B device-bound passkeys only (no synced passkeys)

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: both needed, because the research describes the synced path skipping the prompt

Assumes: malware already on the endpoint; synced passkey path can be driven without the local prompt (verify)

Source: Palo Alto Unit 42, Pass the Passkey; Black Swan advisory 8 Sep 2026 (excerpts). Source read: Partly confirmed.

6

LINK 3 OF 7

Trust

Who vouches for the user, and is that voucher checked?

21	21	17	0
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Assertion replay and audience checks, exact redirects, PKCE, signing key care, pinned federation and CI/CD trust.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

S01 SAML assertion replay after the first use

3. Trust · Run 1 · SSO protocols

What I wrote first	Assertion replayed: accepted twice / one-time id check: second refused / off: accepted
Limit I expected	Replay inside the same second across two servers not modelled

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: OASIS SAML 2.0. Source read: not read yet.

S02 SAML assertion with missing or wrong audience accepted

3. Trust · Run 1 · SSO protocols

What I wrote first	Wrong audience accepted / audience check: refused / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: OASIS SAML 2.0. Source read: not read yet.

S03 SAML signature on the wrong element (signature wrapping)

3. Trust · Run 1 · SSO protocols

What I wrote first	Signature wrapping: forged assertion accepted / strict signature-to-element check: refused / off: accepted
Limit I expected	Parser library flaws not modelled

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: OASIS SAML 2.0; research. Source read: not read yet.

S04 SAML clock skew: expired assertion still accepted

3. Trust · Run 1 · SSO protocols

What I wrote first	Expired assertion accepted / time check: refused / off: accepted
Limit I expected	Skew allowance leaves a small window; I expect to record it

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: OASIS SAML 2.0. Source read: not read yet.

S05 OIDC ID token with wrong nonce accepted

3. Trust · Run 1 · SSO protocols

What I wrote first	Wrong nonce accepted / nonce check: refused / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: OpenID Connect Core. Source read: not read yet.

S06 OIDC redirect URI matched by prefix, not exact

3. Trust · Run 1 · SSO protocols

What I wrote first	Prefix-matched redirect URI: attacker URI accepted / exact match: refused / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: RFC 9700 (OAuth security BCP); verify. Source read: Confirmed.

S07 OAuth authorization code intercepted: PKCE absent

3. Trust · Run 1 · SSO protocols

What I wrote first	Code intercepted, no PKCE: exchanged by attacker / PKCE: refused / off: exchanged
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: RFC 7636. Source read: not read yet.

S08 OAuth state parameter missing, and no PKCE or nonce either: login CSRF

3. Trust · Run 1 · SSO protocols

What I wrote first	No state: login CSRF works / state check: refused / off: works
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: RFC 9700; verify. Source read: Confirmed, with a qualifier.

S13 App keeps a local login beside SSO

3. Trust · Run 1 · SSO protocols

What I wrote first	Local login beside SSO: bypasses SSO rules / local login disabled: closed / off: open
Limit I expected	Break-glass local login is a deliberate exception

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Draft 4 Nov. Source read: not read yet.

S14 IdP signing key rotated and one app still trusts the old key

3. Trust · Run 1 · SSO protocols

What I wrote first	Old signing key still trusted by one app: forged token accepted / remove old key: refused / off: accepted
Limit I expected	Overlap period during rotation is a real window

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Own catalogue. Source read: not read yet.

Z03 Golden SAML: forged assertion signed with a stolen IdP signing key; no IdP sign-in event

3. Trust · Run 1 · SSO protocols

What I wrote first	Golden SAML: forged assertion for any user accepted; IdP log shows no sign-in / key in HSM, assertions logged at app: forging blocked or seen / off: accepted unseen
Limit I expected	Stolen key before HSM use still works

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Obsidian Security SSO bypass blog. Source read: Confirmed.

Z04 Silver SAML: forged assertion for one app using a key the app trusts

3. Trust · Run 1 · SSO protocols

What I wrote first	Silver SAML: forged for one app accepted / app pins its trusted key: refused / off: accepted
Limit I expected	Same limit as Z03

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Obsidian Security SSO bypass blog. Source read: Confirmed.

Z05 ID token signature or algorithm not verified by the app (library flaw)

3. Trust · Run 1 · SSO protocols

What I wrote first	ID token with alg none or bad signature accepted / signature and alg allow-list: refused / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: guptadeepak.com; CVE-2020-26244 as cited. Source read: Confirmed.

Z06 OIDC mix-up: app with two IdPs sends the code to the wrong one

3. Trust · Run 1 · SSO protocols

What I wrote first	Mix-up: code sent to wrong IdP accepted / issuer check: refused / off: accepted
Limit I expected	Apps with one IdP are not exposed

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: guptadeepak.com; OAuth security BCP. Source read: Partly confirmed.

Z07 Unverified email at the IdP lets an attacker sign in as the victim at the app

3. Trust · Run 1 · SSO protocols

What I wrote first	Unverified email at IdP: attacker signs in as victim / app requires verified email and stable subject id: refused / off: signed in
Limit I expected	Apps that match on email alone stay exposed

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: PortSwigger Web Security Academy, OAuth. Source read: Confirmed.

Y03 Federated domain backdoor: an admin adds the attacker's own federated domain, which forges tokens and claims MFA was done

3. Trust · Run 3 · Federation

Bad outcome	attacker signs in as any user with MFA treated as done
Controls	A alert on federation change, B federation change needs a second approver, C cloud MFA required whatever the federated IdP claims

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: A is a notice, it never stops it; B or C alone is enough

Assumes: attacker has a Global Admin session; second approver is a different, honest person; alert is read after the fact

Source: Tenable indicators of exposure, Known Federated Domain Backdoor; Microsoft and Mandiant Solorigate write-ups as cited there. Source read: Confirmed.

Y04 Tenant accepts the federated IdP's MFA claim, and the on-premises IdP skips MFA for internal addresses

3. Trust · Run 3 · Federation

Bad outcome	password-only sign-in from a compromised internal workstation
Controls	A cloud MFA required whatever the claim says, B IdP stops skipping MFA for internal addresses

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	not tested
My guess	happens	stopped	stopped	stopped	not tested

My reasoning when I guessed: either alone is enough

Assumes: attacker is on a compromised internal workstation with the user's password only

Source: Microsoft Learn, migrate from federation to cloud authentication (excerpt). Source read: Confirmed, with a qualifier.

Y11 MCP proxy confused deputy: a malicious client registers itself and skips consent because of an old consent cookie

3. Trust · Run 3 · Agents and MCP

Bad outcome	attacker gets an authorization code with no user consent
Controls	A per-client consent screen owned by the MCP server, B redirect URIs limited to a pre-registered list, C consent cookie set only after consent

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: each one alone breaks the attack

Assumes: victim declines consent for a client they do not know; attacker registers a client with his own redirect URI

Source: Model Context Protocol security best practices (2026-07-28 edition, excerpt). Source read: Confirmed.

W01 OIDC trust scoped to the identity provider, not to the repository and branch

3. Trust · Run 5 · CI/CD and DevOps

Bad outcome	a workflow in someone else's repository gets production cloud credentials
Controls	A cloud trust policy pins the repository and branch (not just the identity provider), B workflows from pull requests cannot request a cloud token, C deploy role has narrow permissions

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: only A decides; B covers pull requests but not a workflow in another repository, C limits damage but not the grant

Source: Cloud Security Alliance note on OIDC trust chain abuse (Mar 2026); NHI Mgmt Group (excerpts). Source read: Confirmed.

W05 VPN accepts a second login method that never asks the identity provider for MFA (verify)

3. Trust · Run 5 · APIs and integrations

Bad outcome	remote access session that never touched the identity provider's MFA (verify)
Controls	A every login method except SAML is switched off on the gateway, B vendor fix applied, C alert on sessions with no matching identity provider sign-in

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: C is a notice, it never stops it; A or B alone closes the path; one source only, a blog

Source: SonicWall advisory SNWLID-2026-0014, revision 1.1 (vendor page); CISA KEV entry; SecurityWeek. Source read: Confirmed.

W11 MCP client takes OAuth discovery data from the server it is connecting to (verify)

3. Trust · Run 5 · Agents and MCP

Bad outcome	the client sends the user's login to an attacker-controlled authorization endpoint (verify)
Controls	A the client accepts only authorization servers from its own allow-list, B the client checks that the issuer in the discovery data matches the server it connected to, C the user checks the sign-in address

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: B alone is not enough: a malicious server's own metadata names itself as the issuer, so it matches; C alone is not enough, see assumption

Source: GitHub advisory GHSA-qx49-fqc8-xw99 as read in the CSA research note (30 Sep 2026), The Hacker News and WorkOS; MCP authorization specification. Source read: Confirmed, with a qualifier.

LINK 4 OF 7

7 Decide

Does a rule cover this sign-in, and does it say the right thing?

33	32	26	3
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Default deny, no broad exceptions, report-only first, device and context signals that cannot be faked.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

A04 Workload identity subject to a human MFA rule

4. Decide · Run 2 · Privileged roles

Bad outcome	outage or unprotected workload
Controls	A workload identity rule (location), B exclude workloads from user rules

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

Source: Own catalogue. Source read: not read yet.

A05 Guest or partner user not covered by internal rules

4. Decide · Run 2 · Privileged roles

Bad outcome	guest in without real MFA
Controls	A trust home-tenant MFA claim for guests, B guest MFA in our tenant

	None on	All on	Off A	Off B	Off C
Output	happens	happens	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

A cell with a dark outline is where my guess was wrong.

My reasoning when I guessed: off B: a weak home tenant claim is accepted

Source: Vendor docs; verify. Source read: Confirmed.

C03 App outside SSO plus exclusion group plus no alert

4. Decide · Run 2 · Chain tests

Bad outcome	attacker in via local login or excluded account, unnoticed
Controls	A put the app behind SSO, B review exclusions, C alert on exclusion use

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	happens	stopped

A cell with a dark outline is where my guess was wrong.

Source: Draft 4 Nov. Source read: not read yet.

C04 Report-only skipped plus emergency account missed plus no alert

4. Decide · Run 2 · Chain tests

Bad outcome	lockout at enforcement
Controls	A report-only, B automatic exclusion of emergency accounts, C alert

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	stopped
My guess	happens	stopped	stopped	happens	stopped

Source: Microsoft Learn plan CA. Source read: not read yet.

P01 Two policies conflict: block and grant both match

4. Decide · Run 2 · Policy logic

Bad outcome	user allowed who should be blocked
Controls	A block overrides grant (verify), B alert on policy change

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Vendor docs; verify. Source read: Confirmed.

P02 Policy scoped to 'all apps' but one app is outside the IdP

4. Decide · Run 2 · Policy logic

Bad outcome	app reachable with no rule
Controls	A app inventory, B put app behind the IdP

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: B cannot protect an app nobody listed

Source: Draft 4 Nov. Source read: not read yet.

P03 Exclusion group grows by one person a month

4. Decide · Run 2 · Policy logic

Bad outcome	exclusion group above 5 members after 6 months
Controls	A exclusions need owner and end date, B monthly review

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	not tested
My guess	happens	stopped	stopped	stopped	not tested

My reasoning when I guessed: either alone is enough

Source: Draft 4 Nov. Source read: not read yet.

P04 Emergency accounts excluded from every rule, alert on use

4. Decide · Run 2 · Policy logic

Bad outcome	lockout or unnoticed use
Controls	A emergency accounts excluded from every rule, B alert on their use

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: off B: signs in, nobody told

Source: Microsoft Learn plan CA. Source read: not read yet.

P05 Emergency account not excluded from one new rule: lockout

4. Decide · Run 2 · Policy logic

Bad outcome	emergency account locked out
Controls	A check exclusion before enabling a rule, B report-only week

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: report-only misses an account that never signs in

Source: Microsoft Learn plan CA. Source read: not read yet.

P06 Report-only run shows who would be blocked; enforcement later

4. Decide · Run 2 · Policy logic

Bad outcome	legit users blocked at enforcement
Controls	A report-only 7 days, B someone reads the log

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

Source: Microsoft Learn plan CA. Source read: not read yet.

P07 Rule enforced with no report-only week

4. Decide · Run 2 · Policy logic

Bad outcome	more than 5 percent of users blocked at any time
Controls	A pilot group first, B rollback switch

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: off B: pilot stays blocked but stays under 5 percent

Source: Microsoft Learn plan CA. Source read: not read yet.

P08 Legacy sign-in protocol skips MFA

4. Decide · Run 2 · Policy logic

Bad outcome	attacker in with password only
Controls	A block legacy sign-in, B MFA on modern sign-in

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

Source: Vendor docs; verify. Source read: Confirmed, with a qualifier.

P09 Service account blocked by a user rule

4. Decide · Run 2 · Policy logic

Bad outcome	outage or unprotected service account
Controls	A exclude service accounts from the user MFA rule, B IP-restricted rule for service accounts

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: off A: outage; off B: unprotected

Source: Draft 4 Nov. Source read: not read yet.

P10 Rule order or precedence misunderstood

4. Decide · Run 2 · Policy logic

Bad outcome	policy gives weaker control than intended
Controls	A written test plan with expected results, B peer review

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	not tested
My guess	happens	stopped	stopped	stopped	not tested

My reasoning when I guessed: either alone catches it

Source: Vendor docs; verify. Source read: Confirmed.

X01 Managed device required: unmanaged laptop with valid MFA

4. Decide · Run 2 · Context signals

Bad outcome	data downloaded to unmanaged device
Controls	A managed device required, B browser-only session on unmanaged devices

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	not tested
My guess	happens	stopped	stopped	stopped	not tested

Source: Vendor docs; verify. Source read: Confirmed.

X02 Device compliance claim is stale

4. Decide · Run 2 · Context signals

Bad outcome	device non-compliant for 3 days still allowed
Controls	A compliance freshness check (24 hours), B event-based revoke

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: off A: offline device sends no event

Source: Vendor docs; verify. Source read: Confirmed, with a qualifier.

X03 Country block: user on VPN exit in a blocked country

4. Decide · Run 2 · Context signals

Bad outcome	real traveller wrongly blocked
Controls	A country block, B named traveller exception with end date

	None on	All on	Off A	Off B	Off C
Output	stopped	stopped	stopped	happens	not tested
My guess	stopped	stopped	stopped	happens	not tested

My reasoning when I guessed: off B in means: block on, no exception

Source: Draft 4 Nov. Source read: not read yet.

X04 Country block: attacker uses a proxy in an allowed country

4. Decide · Run 2 · Context signals

Bad outcome	attacker in via proxy in an allowed country
Controls	A country block, B device compliance

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

Source: Draft 4 Nov. Source read: not read yet.

X05 Risk-based step-up: low risk score on a real attack

4. Decide · Run 2 · Context signals

Bad outcome	attacker in sensitive app with low risk score
Controls	A risk-based step-up, B phishing-resistant MFA on sensitive apps

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

Source: Vendor docs; verify. Source read: Confirmed.

X06 Risk-based block: high false positive on a travelling user

4. Decide · Run 2 · Context signals

Bad outcome	real travelling user blocked over 1 hour
Controls	A risk-based block, B self-service remediation

	None on	All on	Off A	Off B	Off C
Output	stopped	stopped	stopped	happens	not tested
My guess	stopped	stopped	stopped	happens	not tested

Source: Vendor docs; verify. Source read: Confirmed.

X07 Trusted network exception used from a guest wifi in the same range

4. Decide · Run 2 · Context signals

Bad outcome	attacker on guest wifi skips MFA
Controls	A trusted location = managed office egress only, B device compliance

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	not tested
My guess	happens	stopped	stopped	happens	not tested

A cell with a dark outline is where my guess was wrong.

Source: Own catalogue. Source read: not read yet.

Z09 ROPC (password sent straight to the token endpoint) cannot perform MFA

4. Decide · Run 2 · Auth flows

Bad outcome	password-only token
Controls	A block legacy and ROPC in policy, B disable ROPC on app registrations, C alert on ROPC use

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

Source: Huntress CA misconfigurations blog. Source read: Confirmed, with a qualifier.

Z11 A policy blocks one named client (e.g. a CLI) but the same flow arrives via another client

4. Decide · Run 2 · Auth flows

Bad outcome	same flow via another client
Controls	A block one named client, B block the whole flow

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

Source: Huntress CA misconfigurations blog. Source read: Partly confirmed.

Z12 Policy has too many AND conditions (e.g. sign-in risk and user risk) and rarely fires

4. Decide · Run 2 · Policy logic

Bad outcome	attack sign-in outside the policy
Controls	A reduce to one condition, B alert on sign-ins no policy covered

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: B only alerts, does not fix

Source: Compass Security, Entra findings part 4. Source read: Confirmed.

Z13 No default deny: a sign-in no policy matches is allowed

4. Decide · Run 2 · Policy logic

Bad outcome	sign-in matching no policy allowed
Controls	A baseline MFA for all users and apps, B block unknown client types

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Compass Security, Entra findings part 4. Source read: Confirmed.

Z14 Built-in bypass: compliant-device rule still allows security-info registration or device join

4. Decide · Run 2 · Policy logic

Bad outcome	attacker registers own MFA
Controls	A dedicated registration policy, B alert on new method registration

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Compass Security, Entra findings part 4. Source read: Confirmed.

Z15 Policy drift: console edits diverge from the approved baseline (policy as code)

4. Decide · Run 2 · Policy logic

Bad outcome	console edit lasts over 24 hours
Controls	A policy as code applied weekly, B daily drift detection

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	stopped	happens	not tested

My reasoning when I guessed: A alone: edit survives up to 7 days, so I expect off B in

Source: T-Minus 365; Cloud Capsule. Source read: Partly confirmed.

Z16 Device platform condition relies on a user agent string the attacker can change

4. Decide · Run 2 · Context signals

Bad outcome	spoofed platform string bypasses a block
Controls	A device compliance, B platform condition

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Microsoft Learn CA conditions. Source read: Confirmed.

Z17 AiTM session replay refused because policy needs a compliant device

4. Decide · Run 2 · Context signals

Bad outcome	AiTM session replay works
Controls	A compliant device at replay, B token protection, C phishing-resistant MFA

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: I expect any one control alone is enough

Source: Microsoft Entra blog AiTM; r/DefenderATP. Source read: Partly confirmed.

Z20 Printers and scanners justify a broad legacy-auth exception

4. Decide · Run 2 · Policy logic

Bad outcome	attacker uses the exception from outside
Controls	A legacy exception limited to the printer IP, B exception has an end date

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: T-Minus 365; Cloud Capsule; Exchange Team blog, 27 Jan 2026 (updated 29 Jan). Source read: Confirmed.

Y05 Native app signs in without the broker, so device identity is missing and a device rule cannot be checked

4. Decide · Run 3 · Mobile and native apps

Bad outcome	sign-in from an unmanaged personal phone
Controls	A require a compliant device, B require the broker (approved client)

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: assumes an app with no device identity is refused, not waved through

Assumes: attacker's own unmanaged phone; Authenticator broker can be installed by anyone; unknown device state = refuse

Source: intuneirl.com, brokered authentication iOS and Android; Microsoft Learn MSAL web browsers (excerpts). Source read: Confirmed.

Y06 Token obtained through a nested app path that the conditional access policy does not evaluate (verify)

4. Decide · Run 3 · Mobile and native apps

Bad outcome	attacker with password and relayed MFA gets a token from an unmanaged host through the nested path (verify)
Controls	A policy covers all resources and client paths, B compliant device checked at token issue

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: B is part of the policy A decides the reach of

Assumes: attacker has password and relayed MFA; unmanaged host; policy engine skips paths it does not target (verify)

Source: NetSPI, nested app authentication bypass; TROOPERS 2026 talk abstract. Source read: Confirmed, with a qualifier.

E01 Real identity provider sign-in logs and report-only export

4. Decide · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: Vendor docs. Source read: not read yet.

LINK 5 OF 7

8 Issue

What does the token allow, for how long, and to whom?

16	16	10	1
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Narrow scope, short life, binding to the client, refresh rotation and a maximum age, no stored secrets.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

S09 Token audience not checked by the API

5. Issue · Run 1 · SSO protocols

What I wrote first	API accepts token for another audience / audience check: refused / off: accepted
Limit I expected	None

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: RFC 9068; verify. Source read: Confirmed.

S10 Refresh token not rotated or bound (public client)

5. Issue · Run 1 · SSO protocols

What I wrote first	Refresh token stolen: works repeatedly / rotation with reuse detection: stolen use detected on second use / off: works
Limit I expected	The first use by the thief succeeds before detection

	No control	Control on	Control off alone
Output	happens	not tested	happens
My guess	happens	not tested	happens

Source: RFC 9700; verify. Source read: Confirmed, with a qualifier.

C02 Token replay plus long session plus no device check

5. Issue · Run 2 · Chain tests

Bad outcome	stolen token works at 30 minutes or at 4 hours
Controls	A compliant device at token use, B session lifetime 1 hour, C location revoke

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

Source: Research; verify. Source read: Partly confirmed.

X08 Token stolen after MFA is replayed from another device

5. Issue · Run 2 · Context signals

Bad outcome	stolen token replayed from the same country
Controls	A compliant device at token use, B location-based revoke

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Research; verify. Source read: Confirmed, with a qualifier.

X09 Silent token renewal keeps a session alive past the intended re-sign-in interval

5. Issue · Run 2 · Context signals

Bad outcome	stolen session works after 8 hours
Controls	A sign-in frequency 1 hour, B access token lifetime 1 hour

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: refresh tokens renew quietly without A

Source: Vendor docs; verify. Source read: Partly confirmed.

Z08 OAuth device code phishing: victim enters an attacker code at the real IdP; attacker gets tokens

5. Issue · Run 2 · Auth flows

Bad outcome	attacker gets tokens
Controls	A block device code flow, B prompt "only enter codes you started" (assume 60 percent resist)

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: off A: 40 of 100 users still fall

Source: Huntress; Dark Atlas; Microsoft Learn authentication flows. Source read: Confirmed.

Z10 OAuth consent phishing: malicious app granted access with no password stolen

5. Issue · Run 2 · Auth flows

Bad outcome	malicious app reads mail
Controls	A user consent limited to verified publishers, B admin consent workflow, C app governance alert

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

Source: Microsoft Entra blog, OAuth consent phishing. Source read: Partly confirmed.

Z19 Refresh token valid for 90 days of inactivity with no maximum age, so it may outlive a password reset

5. Issue · Run 2 · Context signals

Bad outcome	attacker token works 1 hour after reset
Controls	A revoke sessions on password reset, B sign-in frequency 8 hours

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Huntress blog; verify. Source read: Confirmed, with a qualifier.

Z21 Device code phishing plus no flow block plus long refresh token

5. Issue · Run 2 · Chain tests

Bad outcome	attacker has access at 24 hours
Controls	A block device code flow, B refresh token 1 hour, C compliant device at use

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

Two controls off together (A and C): output out, I guessed in. This was the wrong guess.

My reasoning when I guessed: I expect A and C off together to give in; B does not matter

Source: Huntress; Compass Security. Source read: Partly confirmed.

Y12 MCP server accepts a token issued for another service and passes it on to a downstream API

5. Issue · Run 3 · Agents and MCP

Bad outcome	attacker acts as the user at the downstream API with a token issued for another service
Controls	A token audience checked by the MCP server, B downstream call uses the server's own exchanged token, C downstream API checks audience

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: only A stops it; B and C see a valid token once the server has accepted it

Assumes: attacker holds a token issued for another service (audience = 'payroll-api'); downstream is 'ledger-api'

Source: Model Context Protocol security best practices; Aembit; WorkOS (excerpts). Source read: Confirmed.

Y13 Agent includes its own token in data sent to a tool; the token is long lived and broad

5. Issue · Run 3 · Agents and MCP

Bad outcome	a leaked token is still useful after 1 hour or outside the task
Controls	A short token life (under 1 hour), B narrow scope for the task

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	not tested
My guess	happens	stopped	happens	happens	not tested

My reasoning when I guessed: the leak is assumed; both limits are needed

Assumes: the leak happens; attacker uses the token 2 hours later and tries data outside the task

Source: Aembit, MCP authentication and authorization patterns (excerpt). Source read: Confirmed.

W02 Poisoned third-party action steals CI secrets that outlive the run

5. Issue · Run 5 · CI/CD and DevOps

Bad outcome	an attacker holds a cloud credential that still works 24 hours after a poisoned action ran
Controls	A third-party actions pinned to a commit, B workflow token has the minimum permissions, C short-lived cloud tokens instead of stored cloud keys

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: each one alone leaves no 24-hour credential; assumes the cloud session lasts at most 1 hour and cannot mint new credentials

Source: NHI Mgmt Group on tj-actions and reviewdog (2025); excerpts only. Source read: not read yet.

W03 Pull request from outside runs with a privileged trigger and gets a cloud or publish token

5. Issue · Run 5 · CI/CD and DevOps

Bad outcome	code from an outside pull request gets a cloud or publish token
Controls	A privileged triggers never check out or run code from a pull request, B secrets not exposed to workflows from forks, C cloud token request allowed only on protected branches

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: each one alone breaks the path; the real cases chained two mistakes

Source: CSA Megalodon note (May 2026); cipherwatch TanStack write-up (one blog, verify). Source read: not read yet.

W09 Stolen access token replayed from another machine, with and without client binding

5. Issue · Run 5 · APIs and integrations

Bad outcome	a stolen access token replayed from another machine within its lifetime
Controls	A access tokens bound to the client (DPoP or mutual TLS), B access tokens last 5 minutes, C refresh tokens rotate

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: assumes the attacker uses it within minutes of stealing it, so B does not help; C is irrelevant to an access token

Source: Own catalogue; RFC 9449 (DPoP) not read. Source read: Confirmed.

G06 Token stolen from an employee's personal AI agent still works 7 days later

5. Issue · Run 6 · AI agent identity

Bad outcome	a token stolen from an employee's personal AI agent still works 7 days later
Controls	A the identity provider issues no refresh token to an agent client that is not registered and approved, B refresh tokens end 24 hours after sign-in even when rotated, C tokens bound to the device

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: each one alone closes it

Source: Ping Identity Enterprise Personal Agent Access (1 Sep 2026; Help Net Security excerpt). Source read: Partly confirmed.

G09 Secret copied from a build log still works 30 days later

5. Issue · Run 6 · AI agent identity

Bad outcome	a secret copied from a build log still works 30 days later
Controls	A the workload uses 1-hour federated tokens instead of a stored secret, B secret scanning revokes a leaked secret within 1 day, C stored secrets rotate every 90 days

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: A or B alone closes it; assumes the scanner reads build logs

Source: Zscaler on OIDC and SPIFFE short-lived workload access. Source read: Partly confirmed.

LINK 6 OF 7

9 Act

Is the sensitive action checked when it happens, not only at sign-in?

14	13	12	1
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Step-up checked by the server, every credential type covered, actions limited to what the human named and may do.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

A02 Admin role activation without fresh MFA

6. Act · Run 2 · Privileged roles

Bad outcome	attacker activates admin role from stolen session
Controls	A fresh MFA at role activation, B activation limited to 1 hour

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Vendor docs; verify. Source read: Confirmed.

A03 Privileged user signs in to a non-admin app and carries admin session

6. Act · Run 2 · Privileged roles

Bad outcome	admin session on a risky app
Controls	A separate admin accounts, B block admin group on non-admin apps

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	not tested
My guess	happens	stopped	happens	stopped	not tested

A cell with a dark outline is where my guess was wrong.

My reasoning when I guessed: off A: daily account is not in the admin group

Source: Own catalogue. Source read: not read yet.

Y01 Privileged app says step-up is required but its server never checks that the token shows fresh MFA

6. Act · Run 3 · PAM and step-up

Bad outcome	privileged action done with no fresh MFA
Controls	A app checks the token for fresh MFA, B IdP forces step-up when the app asks

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

My reasoning when I guessed: off B: the app refuses, which is not the bad outcome; the check lives in the app

Assumes: attacker holds a session opened 6 hours ago with MFA; he has no second factor; the app asks the IdP for step-up

Source: AuthMind privileged access and MFA bypass page (vendor, excerpt). Source read: Confirmed.

Y02 Scheduled job or API integration runs with no active user session, so the step-up challenge never fires

6. Act · Run 3 · PAM and step-up

Bad outcome	privileged action with no step-up by any path
Controls	A step-up on interactive sessions, B background jobs run as a service identity with its own scope, C user-delegated background tokens blocked for privileged scopes

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: B or C alone closes the background path; only A covers interactive

Assumes: privileged scopes exist; a background job holds a user-delegated token; step-up needs a live session

Source: Salesforce Help, step-up authentication notice (excerpt). Source read: Confirmed.

Y07 Token used from inside the compliant device itself, through a malicious browser extension

6. Act · Run 3 · Mobile and native apps

Bad outcome	attacker uses the session from inside the compliant device
Controls	A compliant device at token use, B token bound to the device, C only approved browser extensions

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	happens
My guess	happens	stopped	stopped	stopped	happens

My reasoning when I guessed: only C stops it; A and B protect against replay from elsewhere

Assumes: attacker code runs inside the user's browser on the compliant, managed device

Source: Mitiga, hunting conditional access bypass in the wild (excerpt). Source read: Confirmed.

Y14 Agent runs an irreversible action because injected text told it to; the token allows it and nobody asks a person

6. Act · Run 3 · Agents and MCP

Bad outcome	irreversible action runs on injected text
Controls	A per-call permission check, B person confirms irreversible actions, C server marks which actions are irreversible

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	happens
My guess	happens	stopped	stopped	happens	happens

My reasoning when I guessed: A allows it, so it does not help; B needs C to know what to ask about

Assumes: prompt injection in a document tells the agent to delete records; the token allows delete

Source: Curity, MCP authorization is not enough; WorkOS, MCP and zero trust (excerpts). Source read: Partly confirmed.

Y16 Malicious MCP client plus broad agent token plus long token life

6. Act · Run 3 · Chain tests

Bad outcome	attacker holds a token that is broad or lasts over 1 hour
Controls	A per-client consent, B narrow token scope, C short token life

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: A stops it; if A fails, B and C together make the token small

Assumes: malicious MCP client tries to get a token; if it gets one, it is judged broad or long

Source: MCP security best practices; Aembit. Source read: Partly confirmed.

E05 Real admin agent handling a ticket that carries a reset instruction for another account

6. Act · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: Ping Identity admin agents (Sep 2026). Source read: not read yet.

W04 Deploy approval abused: phished approver, self-approval, or swap after approval

6. Act · Run 5 · CI/CD and DevOps

Bad outcome	a malicious change deploys to production with an approval on record
Controls	A approver must use phishing-resistant MFA, B requester cannot approve their own change, C approval tied to the exact commit

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	happens
My guess	happens	stopped	happens	happens	happens

My reasoning when I guessed: three different paths: a phished approver, a self-approval, and a swap after approval; no control is redundant

Source: Own catalogue. Source read: not read yet.

W06 Stolen third-party integration token reads customer records, no MFA event

6. Act · Run 5 · APIs and integrations

Bad outcome	attacker exports customer records using a stolen integration token
Controls	A integration token scoped to only the objects it needs, B token usable only from the vendor's addresses, C tokens expire daily and rotate

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	happens	stopped
My guess	happens	stopped	stopped	happens	stopped

My reasoning when I guessed: only B stops use from the attacker's address; A limits what is lost, but the integration legitimately reads those records; C does nothing against use within a day; allow-listing as a control is (verify)

Source: Anomali, McDermott Will and Schulte on Salesloft Drift (Aug 2025); excerpts. Source read: not read yet.

W08 Privileged API accepts a key, a replayed refresh token or a service token, none with step-up

6. Act · Run 5 · APIs and integrations

Bad outcome	a privileged API call made with a credential that skipped step-up
Controls	A API keys not accepted on privileged endpoints, B privileged calls need a fresh step-up claim, C client-credentials tokens limited to service scopes

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	happens
My guess	happens	stopped	happens	happens	happens

My reasoning when I guessed: three paths: a key, a replayed refresh token, a service token with user-level scope; each control closes a different one

Source: Own catalogue; RFC 9470 (see Y01). Source read: not read yet.

W10 Agent with a broad token changes records it was not asked to touch after injected text

6. Act · Run 5 · Agents and MCP

Bad outcome	an agent changes or deletes records it was not asked to touch, after reading injected text
Controls	A each task gets its own narrow token, B a person approves every write, C every tool call is logged

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: C is a notice and never stops it; B alone is not enough if the person approves without reading; assumption below

Source: Arcade on Context.ai (Mar 2026); OWASP agentic Top 10 excerpts. Source read: not read yet.

G02 Admin agent resets another user's password after reading injected text in a ticket

6. Act · Run 6 · AI agent identity

Bad outcome	an admin agent resets another user's password after reading injected text in a ticket
Controls	A the agent may act only on the account the human named in the request, B high-risk actions need the human to confirm with the target shown, C every action is logged

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: C is a notice; B alone is not enough if the person confirms without reading; same assumption as W10

Source: Ping Identity admin agents for Gemini Enterprise (Sep 2026; ITPro and ITWire excerpts). Source read: Partly confirmed.

G03 Sub-agent writes to a system the human who asked cannot write to

6. Act · Run 6 · AI agent identity

Bad outcome	a sub-agent writes to a system the human who asked cannot write to
Controls	A a sub-agent's token is narrowed to the parent's scope and the task (token exchange), B sub-agent tokens last 10 minutes, C the resource checks every delegated action against the human's own permissions

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	happens
My guess	happens	stopped	stopped	stopped	happens

My reasoning when I guessed: only C decides: the orchestrator has its own broad scope, so narrowing to the parent's scope still allows the write; B limits time, not reach

Source: Cloud Security Alliance, Defining Non-Human Identity (22 Jul 2026). Source read: Confirmed.

LINK 7 OF 7

10 Watch and end

When something changes, does access actually stop?

15	13	9	0
cases in this link	run on models	where one control off lets it in	wrong guesses

Controls that decide this link: Revocation that reaches every token, continuous evaluation, expiry with the task, a named owner, logs that name the human.

Each case below shows the bad outcome, the controls, and two rows of results: what the script produced and what I guessed beforehand. Columns read left to right: no controls, all controls, then each control switched off on its own.

S11 Session lifetime longer than token lifetime after logout

7. Watch and end · Run 1 · SSO protocols

What I wrote first	Session outlives logout: still valid / session ends with token: refused / off: valid
Limit I expected	Cached tokens at other apps remain until expiry

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: Own catalogue. Source read: not read yet.

S12 Single logout does not reach one app

7. Watch and end · Run 1 · SSO protocols

What I wrote first	Single logout misses one app: that app stays signed in / logout list complete: none left / off: one stays
Limit I expected	An app that never registered for logout cannot be reached

	No control	Control on	Control off alone
Output	happens	stopped	happens
My guess	happens	stopped	happens

Source: SAML and OIDC logout specs. Source read: not read yet.

P11 Policy changed in the console with no record of who

7. Watch and end · Run 2 · Policy logic

Bad outcome	unauthorised console change unseen for 7 days
Controls	A change log, B approval before change

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Draft 4 Nov. Source read: not read yet.

Z18 Continuous access evaluation: stolen token used from a new location after revoke

7. Watch and end · Run 2 · Context signals

Bad outcome	stolen token works 10 minutes after revoke
Controls	A continuous access evaluation, B 15 minute token lifetime

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	not tested
My guess	happens	stopped	happens	stopped	not tested

Source: Cloud Capsule FAQ; verify. Source read: Confirmed, with a qualifier.

Y10 MFA provider unreachable: the sign-in system fails open and accepts the password alone

7. Watch and end · Run 3 · Resilience

Bad outcome	password-only sign-in accepted during an outage of the main provider
Controls	A fail closed when the provider is unreachable, B emergency accounts outside the MFA path, C second MFA provider

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: A or C alone; B only prevents lockout, it does not touch this outcome

Assumes: main MFA provider is down; attacker has the password; second provider is up if it exists

Source: RSA, how attackers bypass MFA (excerpt); Duo documentation and blog. Source read: Confirmed, with a qualifier.

Y15 Malicious extension steals a session plus a new passkey is registered plus no revoke of recent methods

7. Watch and end · Run 3 · Chain tests

Bad outcome	attacker still has access 24 hours after the user reports and sessions are revoked
Controls	A approved browser extensions only, B fresh strong sign-in to add a method, C revoke methods added since compromise

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: A stops the theft; B or C alone stops the persistence

Assumes: extension steals a session; attacker tries to register a passkey; user reports; sessions are revoked

Source: Mitiga; Black Swan advisory. Source read: Partly confirmed.

E04 Real cross-app agent access: revoke the user's grant and keep calling the second app

7. Watch and end · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: Okta press release on Agent SSO (24 Aug 2026). Source read: not read yet.

E06 Real continuous access evaluation when a session is copied to another network

7. Watch and end · Run 4 · Needs a real tenant

Not run. It needs a real tenant, a hardware key, a real agent product or a person on the phone. Steps and my prediction are in chapter 15.

Source: Okta blog on continuous identity. Source read: not read yet.

W07 Password reset leaves a stolen refresh token alive for 24 hours

7. Watch and end · Run 5 · APIs and integrations

Bad outcome	a stolen session still works 24 hours after the user resets the password (the user does nothing else)
Controls	A password reset revokes refresh tokens and sessions, B changing an MFA method revokes sessions, C access tokens last 1 hour

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: only A applies here; B is never triggered by a password reset; C only ends the access token

Source: Own catalogue; see Z19 (revocation on reset unconfirmed). Source read: not read yet.

G01 Agent keeps reaching a second app after the user revokes its access (cross-app access) (verify)

7. Watch and end · Run 6 · AI agent identity

Bad outcome	the agent still reaches the second app 1 hour after the user revokes its access (verify)
Controls	A revoking the user's grant at the identity provider also revokes tokens already issued to the second app, B second-app access tokens last 5 minutes, C the agent's identity assertion is checked against the current grant every time it is exchanged

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	happens
My guess	happens	stopped	stopped	stopped	happens

My reasoning when I guessed: two paths: the token already issued, which A or B closes, and a new token from a cached assertion, which only C closes; Okta's release does not describe revocation, so the mechanism is my model

Source: Okta press release on Agent SSO (24 Aug 2026). Source read: Confirmed with a qualifier.

G04 Agent credential still works 60 days after its project ended

7. Watch and end · Run 6 · AI agent identity

Bad outcome	an agent credential still works 60 days after its project ended
Controls	A an agent identity expires when its task or project ends, B its credentials rotate every 30 days, C quarterly access review

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	stopped
My guess	happens	stopped	happens	stopped	stopped

My reasoning when I guessed: B gives the agent a new credential, it does not remove it; C finds it only if a review falls in the 60 days

Source: Cloud Security Alliance, Defining Non-Human Identity (22 Jul 2026). Source read: Confirmed.

G05 Ownerless agent still working 30 days after its creator leaves

7. Watch and end · Run 6 · AI agent identity

Bad outcome	an agent with no owner is still working 30 days after the person who created it leaves
Controls	A every agent needs a named human sponsor at creation, B the sponsor leaving triggers reassignment or disable within 7 days, C a monthly scan flags agents with no owner

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	happens	stopped
My guess	happens	stopped	happens	happens	stopped

My reasoning when I guessed: C is a notice; B needs the sponsor record from A to fire, and A needs B to act

Source: Cloud Security Alliance, Defining Non-Human Identity (22 Jul 2026). Source read: Confirmed.

G07 Stolen session cookie still works an hour after MFA (continuous evaluation)

7. Watch and end · Run 6 · AI agent identity

Bad outcome	a stolen session cookie still works more than 1 hour after it was stolen
Controls	A continuous evaluation revokes the session within minutes when the network or device changes, B sessions last 8 hours, C session bound to the device

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: C or A alone closes it; assumes the attacker uses a different network, see assumptions

Source: Okta blog, Beyond SSO and MFA: continuous identity. Source read: Partly confirmed.

G08 Decommissioned agent's certificate still accepted 7 days later (verify)

7. Watch and end · Run 6 · AI agent identity

Bad outcome	a decommissioned agent's certificate is still accepted 7 days later (verify)
Controls	A services check revocation for agent certificates, B agent certificates last 24 hours, C decommissioning an agent revokes its certificate

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	stopped	stopped	stopped
My guess	happens	stopped	stopped	stopped	stopped

My reasoning when I guessed: B alone is enough; A and C only work together; based on a draft, so verify

Source: IETF AIMS draft (via SecureW2 explainer). Source read: Partly confirmed.

G10 Investigator cannot name the human who asked for an agent's action

7. Watch and end · Run 6 · AI agent identity

Bad outcome	30 days later, an investigator cannot name the human who asked for an agent's action
Controls	A every agent call carries the delegating human in the token, B logs share a correlation ID across agent hops, C audit logs kept 90 days

	None on	All on	Off A	Off B	Off C
Output	happens	stopped	happens	stopped	happens
My guess	happens	stopped	happens	stopped	happens

My reasoning when I guessed: B links the hops but the chain starts at a shared service account, so without A the human is never recorded; without C the logs are gone by day 30

Source: Cloud Security Alliance, Defining Non-Human Identity (22 Jul 2026). Source read: Confirmed.

SIX WRONG GUESSES, FIVE KINDS OF MISTAKE

11 What I got wrong

All six wrong guesses were in Run 2. Read together, they fall into five kinds of mistake. Each one is a habit I now check for before I write a guess.

I did not say what I was counting (C01, C03).
I defined the bad outcome as an account takeover that nobody notices. The change notice and the exclusion alert make any takeover noticed, so removing the SMS fallback or the exclusion review alone never produced the bad outcome.

I treated controls as independent (A05).
For guest sign-ins, trusting the home tenant's MFA claim means a weak MFA at home satisfies the requirement in mine. Adding my own guest MFA rule did not help, and with the trust on, all controls on still let the bad outcome in.

I picked the wrong control as the one that mattered (Z21).
I said refresh token lifetime did not matter. The bad outcome was the attacker still having access after 24 hours, which the refresh token lifetime decides. My wrong guess was in the pair test with two controls off together.

I did not think through a control's own scope (X07).
The trusted-network exception was limited to the managed office. Guest wifi in the same range was not trusted, so MFA was required and the attacker was stopped without the device rule.

I counted a convention as a control (A03).
Separate admin accounts are a habit, not enforcement. I had the two cases reversed: with only separate accounts nothing stops the admin account reaching a risky app, while the group block does stop the daily account.

One mistake in my own code

In the first pass of Run 2, my model said approval stops an unauthorised console change (P11). An unauthorised change skips approval by definition, so only the log can show it. I fixed the model and kept the first-pass script and results in the repository. This was a coding mistake, not a wrong guess, and I count it separately.

ONE ASSUMPTION AT A TIME

12 What changes the answer

Every model rests on assumptions I chose: how fast an attacker replays a token, how often people read a prompt, how long a session lasts. For Runs 5 and 6 I changed one assumption at a time and re-ran. This table lists every change and what it did.

Assumption changed	Cases that flipped	What happened
p_no_read 0.02 (people almost always read)	W10, W11	W10: in out in out out became in out out out out; W11: in out in out out became in out out out out
p_no_read 0.60	none	No change.
session_hours 25 (cloud session outlasts the wait)	W02	W02: in out out out out became in out in out out
attacker_delay_min 10 (replay after the short token ends)	W09	W09: in out in out out became in out out out out
b_covers_all_credentials True (step-up check applies to keys and service tokens)	W08	W08: in out in in became in out out in out
p_no_read 0.02 (people almost always read the confirmation)	G02	G02: in out in out out became in out out out out
default_token_min 90 (second-app tokens outlive the hour)	none	No change.
orchestrator_own_identity False (the parent agent acts with the human's own token)	G03	G03: in out out out in became out out out out out
review_interval_days 30 (monthly access review)	G04	G04: in out in out out became in out out out out
attacker_same_network True (attacker replays through a proxy on the victim's network)	G07	G07: in out out out out became in out out out in
scanner_reads_logs False (secret scanning does not cover build logs)	G09	G09: in out out out out became in out in out out
default_retention_days 45 (logs kept 45 days without C)	G10	G10: in out in out in became in out in out out

Read the flips as a list of what to check in your own setup. If your people almost always read a confirmation prompt, approval does real work. If your continuous evaluation only watches the network, an attacker who looks local gets past it. If your secret scanner does not read build logs, it will not find a secret leaked in one.

DATED EVENTS BEHIND THE CASES

13 What companies are suffering

The cases come from public reports. Each event below has a date, the lab cases it relates to, the kind of source, and how far I trust it. Companies appear because the sources name them. A name here says nothing about that company's controls today.

Date	What was reported	Cases	Source and trust
6 Nov 2026	SonicWall SSLVPN: a user with valid credentials for another login method can bypass SAML, including SAML-enforced MFA (CVE-2026-19868). Applies only when SAML is on for VPN logins. SonicWall's advisory says it investigated a report indicating potential exploitation, and CISA added the flaw to its Known Exploited Vulnerabilities list the same day. Fixed in 7.3.4-7013 (Gen7) and 8.2.3-8015 (Gen8). Revision 1.1 on 9 November added a workaround: if SAML is in use and you cannot upgrade, disable or delete the active LDAP, RADIUS and TACACS+ servers.	W05	SonicWall advisory SNWLID-2026-0014, revision 1.1; CISA KEV entry. Confirmed against SonicWall's own page on 14 November. My earlier note said there was no workaround; that was true until revision 1.1. The page's revision table dates version 1.0 as 5 November, its header says 6 November.
28 Sep 2026	The official MCP Python SDK did not check the issuer on a fallback discovery path. A malicious MCP server could make an SDK-based client send its client secret, authorization code and PKCE verifier to an endpoint the server chose (GHSA-qx49-fqc8-xw99, CVSS 7.5). Fixed in 1.30.0 and 2.2.0. No attacks have been reported.	W11	Project security advisory, read through a Cloud Security Alliance note (30 Sep 2026) and The Hacker News. Confirmed, with a qualifier: I did not open the GitHub advisory. MCP was created by Anthropic, whose Claude model helped me draft this lab.
24 Aug 2026	Okta made Agent SSO generally available. It registers AI agents as identities, issues short-lived tokens in place of stored credentials, and moves agent authorization to the identity provider using Cross App Access. The release does not say how revocation works.	G01 E04	Vendor press release. Confirmed as Okta's own announcement, read through a page summary on 14 November. Product claims are the vendor's.
15 Jul 2026	GitHub moves new repositories, and repositories that opt in, to an immutable subject claim in OIDC tokens. Cloud trust policies must include the numeric owner and repository IDs.	W01	Vendor documentation. Confirmed against GitHub's live docs on 14 November, through a page summary. Repositories created after the date use the new format by default, older ones can opt in, and renames and transfers after it also move. Not available on GitHub Enterprise Server.
Reported 17 Mar 2026	Researchers at NetSPI showed that certain nested app authentication flows could return Microsoft Graph tokens without Conditional Access being applied. They told Microsoft on 17 March, Microsoft rated it medium and deployed a fix, and a retest returned Conditional Access blocking errors. Other researchers presented further nested app paths at TROOPERS 2026.	Y06	Researcher write-up. Partly confirmed: I read excerpts of the NetSPI post and a news write-up, not Microsoft's own statement. The fix covers the flows NetSPI named, not every nested app path.

Date	What was reported	Cases	Source and trust
27 Jan 2026	Microsoft revised the Exchange Online timeline for ending Basic authentication on SMTP AUTH (the path older printers and scanners use). It stays unchanged until December 2026, is then disabled by default for existing tenants and unavailable by default for new ones, and a final removal date is due in the second half of 2027. The earlier March to April 2026 dates were put on hold.	Z20	Vendor announcement (Exchange Team blog, updated 29 Jan). Confirmed, through a page summary. Dates have moved before, so check Microsoft's page before you act.
22 Jan 2026	Okta Threat Intelligence described phishing kits built for phone callers. The caller steers what the user sees in step with their script, which defeats any MFA that is not phishing-resistant. Okta says number matching is not phishing-resistant by definition.	M01 M03 M04 Z01 W12	Vendor research by the identity provider; primary for what Okta observed. Confirmed as Okta's own finding. The full advisory is for Okta customers only.
1 Oct 2025	Microsoft began enforcing MFA for Azure resource management at the Azure Resource Manager layer (Phase 2), for CLI, PowerShell, SDKs and REST calls. Tenants could postpone to 1 July 2026. Workload identities such as managed identities and service principals are not covered.	Y01 Y02 W08	Vendor documentation and announcement. Confirmed. Enforcement is gradual by tenant, so your tenant may differ.
8 to 20 Aug 2025	Stolen OAuth and refresh tokens from the Salesloft Drift integration were used to read data from many customers' Salesforce instances between 8 and 18 August. Salesloft and Salesforce revoked all Drift tokens on 20 August. Google later confirmed Drift Email tokens were also compromised.	W06 W07	Google Threat Intelligence Group report, 26 Aug 2025. Confirmed by the investigating team. My reading: tokens like these are used without a fresh sign-in, so MFA had nothing to check.
9 Jul 2025	mcp-remote, a tool that connects AI clients to remote MCP servers, ran operating system commands from a crafted authorization endpoint sent by a malicious server (CVE-2025-6514, CVSS 9.6). Fixed in 0.1.16.	W11	Researcher advisory and CVE record. Confirmed. A related lesson to W11, not the same flaw: the client trusted values the server supplied. W11 matches the Python SDK advisory above.
14 to 18 Mar 2025	The GitHub Action tj-actions/changed-files was compromised and leaked CI/CD secrets through workflow logs (CVE-2025-30066). CISA added it to its Known Exploited Vulnerabilities list.	W02 W03	Government alert. Confirmed.
16 Nov 2023, updated 29 Jul 2025	CISA and the FBI described a group that phones IT help desks, poses as an employee and has the password reset and MFA moved to a device they control.	W12 E03	Government advisory AA23-320A. Confirmed.

WHAT I READ, AND HOW FAR TO TRUST IT

14 Research and development: where vendors and standards are going

I searched once, in November 2026, for what identity vendors and standards bodies are building for non-human identity, AI agents, MFA and SSO. Most of what came back is vendor material or a write-up of it, so each row says what kind of source it is. Product claims are the vendor's.

Who	What (date)	Source type	Used in
Okta	Agent SSO generally available, built on Cross App Access; short-lived tokens in place of stored credentials; agent authorization moved to the identity provider. The release does not say how revocation works (24 Aug 2026).	Vendor press release, read	G01, E04
Okta	Okta for AI Agents generally available (30 Apr 2026); Blueprint Alliance for a reference architecture to secure agents (22 Sep 2026).	Secondary write-up citing Okta	Context
Okta	Argues that SSO and MFA leave session-hijack gaps that continuous identity checks close.	Vendor blog, excerpt	G07, E06
Ping Identity	Enterprise Personal Agent Access for agents employees run themselves (1 Sep 2026); admin agents for Gemini Enterprise that reset passwords and end sessions on request (late Sep 2026).	News excerpts	G02, G06, E05
Cloud Security Alliance	Defining Non-Human Identity: six risk areas for all non-human identities; for agents, a human sponsor each, minimal short-lived delegated access limited to the human's own permissions, and logs naming delegator, agent and intent (22 Jul 2026).	Industry research, read	G03, G04, G05, G10
IETF	AIMS, an emerging draft framework for agent identity using certificates.	Vendor explainer of a draft	G08 (verify)
MCP project	Authorization specification, 2026-07-28 revision: clients find the authorization server from protected resource metadata and check the issuer.	Specification, read	W11, Y11, Y12
GitHub	Immutable OIDC subject claims with owner and repository IDs for repositories created after 15 July 2026.	Vendor documentation, read	W01
Microsoft	SMTP AUTH Basic authentication disabled by default for existing tenants at the end of December 2026; final removal date due in the second half of 2027.	Vendor announcement, read	Z20
SANS	2026 survey: the challenge has moved from buying identity tools to making them work.	Survey, excerpt	Context

What I could test from this

Everything that is rule logic went into Run 6 as a model. Everything that needs the real product went into the hand tests E04 to E06. None of it tests a vendor's product.

RUN IT, BREAK IT, REPORT WHAT YOU FIND

15 The lab for your people

Run the scripts

1. Install Python 3. The scripts use only the standard library.
2. Download a script and its guess file from roshantrivedi.co.in/ca-mfa-lab/evidence/.
3. Check the guess file's hash with `shasum -a 256`. It should match the table in appendix A.
4. Run it, for example `python3 -I run6.py guesses-run6.md`. Each case prints its output, my guess and OK or MISMATCH.
5. Open the script, change one value in PARAMS, run it again, and see which cases change.

The six hand tests

These need something a model cannot stand in for. Use a throwaway test tenant, made-up users and a spare key. Never call a real help desk, and never put a tenant name, password, code or token in your notes.

Test	What it checks	Link
E01	Real identity provider sign-in logs and report-only export	4. Decide
E02	Real FIDO2 hardware key enrolment and loss	1. Enrol and recover
E03	Real help desk call handling	1. Enrol and recover
E04	Real cross-app agent access: revoke the user's grant and keep calling the second app	7. Watch and end
E05	Real admin agent handling a ticket that carries a reset instruction for another account	6. Act
E06	Real continuous access evaluation when a session is copied to another network	7. Watch and end

Report an exception

If you test any case in a real product and it behaves differently from my model, use the exception form on the lab's GitHub. It asks for the case ID, the product and version, what you saw and how you checked. Accepted exceptions go next to my result with a date, and my result stays.

Run it as a team workshop

1. Pick one link from chapter 3 that your team owns.
2. Before anyone opens the results, each person writes a guess for three cases in that link.
3. Compare the guesses, then open the case pages and play each case one column at a time.

4. For every case where someone was surprised, write down the assumption that would make your own setup different.
5. Turn the surprises into checks: a policy review, a test in a test tenant, or a question for your vendor.

WHAT I WOULD CHECK FIRST

16 Conclusion

If I owned sign-in for an organisation tomorrow, I would not start with a new MFA method. I would start with these:

1. Which sign-ins does no rule cover? Look for the default, the exceptions and the legacy paths.
2. Is account recovery at least as strong as sign-in, including the help desk?
3. Does a password reset end refresh tokens and sessions, everywhere?
4. Does every privileged action check fresh MFA on the server, for keys and service tokens too?
5. Does every agent have a named owner, an expiry tied to its task, and a resource that checks the human's own rights?
6. When access is revoked, how long does each kind of token keep working?

This lab cannot tell you how your product behaves. It can tell you which questions to ask, and what the answer depends on. The six hand tests and the exception form are there so people with real tenants can tell me where I am wrong.

A

HASHES, REPRODUCTION AND ASSUMPTIONS

Evidence

Guess files

Run	File	SHA-256
1	guesses-run1.md	`2675a0efa8937fb5ade0910e89c5a2d77ffb4964560bc4778de1157d7305bb62`
2	guesses-run2.md	`f7c8439b21cda129254f4ff6559534afad7833dc880c64408f4dfe82fc2687e2`
3	guesses-run3.md	`a09daa459851a1d9628d21ceeb51c5fd11bd37c6481b39ec0ab9b2e20205cd98`
4	guesses-run4.md	`38f544b069739445cd057b9569970de89870e4cde688f7f6af93e82f248fd94a`
5	guesses-run5.md	`bc344bbd00d01d169c0dbde94d83fc628ec973dcbbb067d1c2cad3f74a65e63a`
6	guesses-run6.md	`1abdbf110b58375570d3472f3aefc697b41931f236a53001c1f9d836f01ec22f`

Reproduction

On 14 November 2026 I reran all five scripts on a second machine, a Mac with macOS on x86_64 and Python 3.9.6. Every results file came out byte for byte identical to the published one. The log had 119 lines ending in OK and 5 ending in MISMATCH, the five Run 2 cases where my guess was wrong. The sixth wrong guess, Z21, is in a pair test that the per-case line does not show.

Assumptions in Runs 5 and 6

Run	Parameter	Value
5	p_no_read	0.3
5	threshold	0.05
5	session_hours	1
5	poison_wait_hours	24
5	attacker_delay_min	2
5	short_token_min	5
5	default_token_min	60
5	b_covers_all_credentials	False
6	threshold	0.05
6	p_no_read	0.3
6	assertion_hours	24
6	check_after_min	60
6	default_token_min	60
6	orchestrator_own_identity	True
6	review_interval_days	90
6	check_day_g04	60
6	attacker_same_network	False
6	scanner_reads_logs	True
6	default_retention_days	7

Runs 1 to 3 keep their assumptions in the header of each script.

B

ALL 130 ROWS

The full register

ID	Case	Link	Run	Result	Source read
M01	SMS or voice code is relayed by a phishing page in real time	Prove	1	guess matched	not read yet
M02	TOTP code is relayed by a phishing page inside its 30 second window	Prove	1	guess matched	not read yet
M03	Push approval with no number match accepted by a tired user (prompt bombing)	Prove	1	guess matched	not read yet
M04	Push with number matching: attacker cannot supply the number	Prove	1	guess matched	not read yet
M05	Passkey or security key on a look-alike domain: origin check refuses	Prove	1	guess matched	not read yet
M06	Passkey synced across devices: loss of one device	Enrol and recover	1	guess matched	Confirmed, with a qualifier
M07	Backup codes reused after first use	Prove	1	guess matched	Confirmed
M08	SMS kept as recovery: attacker picks the weakest allowed method	Enrol and recover	1	guess matched	not read yet
M09	SIM swap moves the SMS factor to the attacker	Enrol and recover	1	guess matched	not read yet
M10	TOTP seed stolen from a shared spreadsheet	Prove	1	guess matched	not read yet
M11	Counter or clock drift on TOTP: allowed window too wide	Prove	1	guess matched	not read yet
M12	Rate limit on wrong codes: 6 digit code guessed without lockout	Prove	1	guess matched	not read yet
M13	Lockout used by an attacker to deny a real user	Prove	1	guess matched	not read yet
M14	Method downgrade: user chooses weaker factor at prompt	Prove	1	guess matched	not read yet
S01	SAML assertion replay after the first use	Trust	1	guess matched	not read yet
S02	SAML assertion with missing or wrong audience accepted	Trust	1	guess matched	not read yet
S03	SAML signature on the wrong element (signature wrapping)	Trust	1	guess matched	not read yet
S04	SAML clock skew: expired assertion still accepted	Trust	1	guess matched	not read yet

ID	Case	Link	Run	Result	Source read
S05	OIDC ID token with wrong nonce accepted	Trust	1	guess matched	not read yet
S06	OIDC redirect URI matched by prefix, not exact	Trust	1	guess matched	Confirmed
S07	OAuth authorization code intercepted: PKCE absent	Trust	1	guess matched	not read yet
S08	OAuth state parameter missing, and no PKCE or nonce either: login CSRF	Trust	1	guess matched	Confirmed, with a qualifier
S09	Token audience not checked by the API	Issue	1	guess matched	Confirmed
S10	Refresh token not rotated or bound (public client)	Issue	1	guess matched	Confirmed, with a qualifier
S11	Session lifetime longer than token lifetime after logout	Watch and end	1	guess matched	not read yet
S12	Single logout does not reach one app	Watch and end	1	guess matched	not read yet
S13	App keeps a local login beside SSO	Trust	1	guess matched	not read yet
S14	IdP signing key rotated and one app still trusts the old key	Trust	1	guess matched	not read yet
R01	Help desk resets MFA after a caller gives name and phone number	Enrol and recover	1	guess matched	not read yet
R02	Method change with no notice to the person	Enrol and recover	1	guess matched	not read yet
R03	Admin reset with no delay	Enrol and recover	1	guess matched	not read yet
R04	Account recovery by email to a mailbox the attacker owns	Enrol and recover	1	guess matched	not read yet
R05	New device enrolment right after a password reset	Enrol and recover	1	guess matched	not read yet
R06	Temporary access pass lifetime too long	Enrol and recover	1	guess matched	Confirmed
P01	Two policies conflict: block and grant both match	Decide	2	guess matched	Confirmed
P02	Policy scoped to 'all apps' but one app is outside the IdP	Decide	2	guess matched	not read yet
P03	Exclusion group grows by one person a month	Decide	2	guess matched	not read yet
P04	Emergency accounts excluded from every rule, alert on use	Decide	2	guess matched	not read yet
P05	Emergency account not excluded from one new rule: lockout	Decide	2	guess matched	not read yet
P06	Report-only run shows who would be blocked; enforcement later	Decide	2	guess matched	not read yet
P07	Rule enforced with no report-only week	Decide	2	guess matched	not read yet

ID	Case	Link	Run	Result	Source read
P08	Legacy sign-in protocol skips MFA	Decide	2	guess matched	Confirmed, with a qualifier
P09	Service account blocked by a user rule	Decide	2	guess matched	not read yet
P10	Rule order or precedence misunderstood	Decide	2	guess matched	Confirmed
P11	Policy changed in the console with no record of who	Watch and end	2	guess matched	not read yet
X01	Managed device required: unmanaged laptop with valid MFA	Decide	2	guess matched	Confirmed
X02	Device compliance claim is stale	Decide	2	guess matched	Confirmed, with a qualifier
X03	Country block: user on VPN exit in a blocked country	Decide	2	guess matched	not read yet
X04	Country block: attacker uses a proxy in an allowed country	Decide	2	guess matched	not read yet
X05	Risk-based step-up: low risk score on a real attack	Decide	2	guess matched	Confirmed
X06	Risk-based block: high false positive on a travelling user	Decide	2	guess matched	Confirmed
X07	Trusted network exception used from a guest wifi in the same range	Decide	2	guess wrong	not read yet
X08	Token stolen after MFA is replayed from another device	Issue	2	guess matched	Confirmed, with a qualifier
X09	Silent token renewal keeps a session alive past the intended re-sign-in interval	Issue	2	guess matched	Partly confirmed
A01	Admin on SMS fallback: phishing-resistant rule has a weaker alternative	Prove	2	guess matched	not read yet
A02	Admin role activation without fresh MFA	Act	2	guess matched	Confirmed
A03	Privileged user signs in to a non-admin app and carries admin session	Act	2	guess wrong	not read yet
A04	Workload identity subject to a human MFA rule	Decide	2	guess matched	not read yet
A05	Guest or partner user not covered by internal rules	Decide	2	guess wrong	Confirmed
C01	Weak SMS fallback plus help desk reset plus no notice	Enrol and recover	2	guess wrong	not read yet
C02	Token replay plus long session plus no device check	Issue	2	guess matched	Partly confirmed
C03	App outside SSO plus exclusion group plus no alert	Decide	2	guess wrong	not read yet
C04	Report-only skipped plus emergency account missed plus no alert	Decide	2	guess matched	not read yet
C05	Passkey fallback to SMS plus SIM swap plus notice missing	Enrol and recover	2	guess matched	not read yet
E01	Real identity provider sign-in logs and report-only export	Decide	4	not run	not read yet

ID	Case	Link	Run	Result	Source read
E02	Real FIDO2 hardware key enrolment and loss	Enrol and recover	4	not run	not read yet
E03	Real help desk call handling	Enrol and recover	4	not run	not read yet
Z01	QR code lure (quishing) sends the user to a look-alike sign-in page	Prove	1	guess matched	Partly confirmed
Z02	Attacker registers their own MFA method after stealing the password	Enrol and recover	1	guess matched	Confirmed
Z03	Golden SAML: forged assertion signed with a stolen IdP signing key; no IdP sign-in event	Trust	1	guess matched	Confirmed
Z04	Silver SAML: forged assertion for one app using a key the app trusts	Trust	1	guess matched	Confirmed
Z05	ID token signature or algorithm not verified by the app (library flaw)	Trust	1	guess matched	Confirmed
Z06	OIDC mix-up: app with two IdPs sends the code to the wrong one	Trust	1	guess matched	Partly confirmed
Z07	Unverified email at the IdP lets an attacker sign in as the victim at the app	Trust	1	guess matched	Confirmed
Z08	OAuth device code phishing: victim enters an attacker code at the real IdP; attacker gets tokens	Issue	2	guess matched	Confirmed
Z09	ROPC (password sent straight to the token endpoint) cannot perform MFA	Decide	2	guess matched	Confirmed, with a qualifier
Z10	OAuth consent phishing: malicious app granted access with no password stolen	Issue	2	guess matched	Partly confirmed
Z11	A policy blocks one named client (e.g. a CLI) but the same flow arrives via another client	Decide	2	guess matched	Partly confirmed
Z12	Policy has too many AND conditions (e.g. sign-in risk and user risk) and rarely fires	Decide	2	guess matched	Confirmed
Z13	No default deny: a sign-in no policy matches is allowed	Decide	2	guess matched	Confirmed
Z14	Built-in bypass: compliant-device rule still allows security-info registration or device join	Decide	2	guess matched	Confirmed
Z15	Policy drift: console edits diverge from the approved baseline (policy as code)	Decide	2	guess matched	Partly confirmed
Z16	Device platform condition relies on a user agent string the attacker can change	Decide	2	guess matched	Confirmed
Z17	AiTM session replay refused because policy needs a compliant device	Decide	2	guess matched	Partly confirmed
Z18	Continuous access evaluation: stolen token used from a new location after revoke	Watch and end	2	guess matched	Confirmed, with a qualifier
Z19	Refresh token valid for 90 days of inactivity with no maximum age, so it may outlive a password reset	Issue	2	guess matched	Confirmed, with a qualifier
Z20	Printers and scanners justify a broad legacy-auth exception	Decide	2	guess matched	Confirmed
Z21	Device code phishing plus no flow block plus long refresh token	Issue	2	guess wrong	Partly confirmed

ID	Case	Link	Run	Result	Source read
Z22	Stolen password plus open security-info registration plus no device rule	Enrol and recover	2	guess matched	Partly confirmed
Y01	Privileged app says step-up is required but its server never checks that the token shows fresh MFA	Act	3	guess matched	Confirmed
Y02	Scheduled job or API integration runs with no active user session, so the step-up challenge never fires	Act	3	guess matched	Confirmed
Y03	Federated domain backdoor: an admin adds the attacker's own federated domain, which forges tokens and claims MFA was done	Trust	3	guess matched	Confirmed
Y04	Tenant accepts the federated IdP's MFA claim, and the on-premises IdP skips MFA for internal addresses	Trust	3	guess matched	Confirmed, with a qualifier
Y05	Native app signs in without the broker, so device identity is missing and a device rule cannot be checked	Decide	3	guess matched	Confirmed
Y06	Token obtained through a nested app path that the conditional access policy does not evaluate (verify)	Decide	3	guess matched	Confirmed, with a qualifier
Y07	Token used from inside the compliant device itself, through a malicious browser extension	Act	3	guess matched	Confirmed
Y08	Pass-the-passkey: malware on the endpoint gets a valid passkey assertion with little or no user action (verify)	Prove	3	guess matched	Partly confirmed
Y09	Attacker with a stolen session registers their own passkey and keeps access after sessions are revoked	Enrol and recover	3	guess matched	Confirmed
Y10	MFA provider unreachable: the sign-in system fails open and accepts the password alone	Watch and end	3	guess matched	Confirmed, with a qualifier
Y11	MCP proxy confused deputy: a malicious client registers itself and skips consent because of an old consent cookie	Trust	3	guess matched	Confirmed
Y12	MCP server accepts a token issued for another service and passes it on to a downstream API	Issue	3	guess matched	Confirmed
Y13	Agent includes its own token in data sent to a tool; the token is long lived and broad	Issue	3	guess matched	Confirmed
Y14	Agent runs an irreversible action because injected text told it to; the token allows it and nobody asks a person	Act	3	guess matched	Partly confirmed
Y15	Malicious extension steals a session plus a new passkey is registered plus no revoke of recent methods	Watch and end	3	guess matched	Partly confirmed
Y16	Malicious MCP client plus broad agent token plus long token life	Act	3	guess matched	Partly confirmed
W01	OIDC trust scoped to the identity provider, not to the repository and branch	Trust	5	guess matched	Confirmed
W02	Poisoned third-party action steals CI secrets that outlive the run	Issue	5	guess matched	not read yet
W03	Pull request from outside runs with a privileged trigger and gets a cloud or publish token	Issue	5	guess matched	not read yet
W04	Deploy approval abused: phished approver, self-approval, or swap after approval	Act	5	guess matched	not read yet
W05	VPN accepts a second login method that never asks the identity provider for MFA (verify)	Trust	5	guess matched	Confirmed
W06	Stolen third-party integration token reads customer records, no MFA event	Act	5	guess matched	not read yet

ID	Case	Link	Run	Result	Source read
W07	Password reset leaves a stolen refresh token alive for 24 hours	Watch and end	5	guess matched	not read yet
W08	Privileged API accepts a key, a replayed refresh token or a service token, none with step-up	Act	5	guess matched	not read yet
W09	Stolen access token replayed from another machine, with and without client binding	Issue	5	guess matched	Confirmed
W10	Agent with a broad token changes records it was not asked to touch after injected text	Act	5	guess matched	not read yet
W11	MCP client takes OAuth discovery data from the server it is connecting to (verify)	Trust	5	guess matched	Confirmed, with a qualifier
W12	Recovery path enrols an attacker's authenticator because it is weaker than sign-in	Enrol and recover	5	guess matched	not read yet
G01	Agent keeps reaching a second app after the user revokes its access (cross-app access) (verify)	Watch and end	6	guess matched	Confirmed with a qualifier
G02	Admin agent resets another user's password after reading injected text in a ticket	Act	6	guess matched	Partly confirmed
G03	Sub-agent writes to a system the human who asked cannot write to	Act	6	guess matched	Confirmed
G04	Agent credential still works 60 days after its project ended	Watch and end	6	guess matched	Confirmed
G05	Ownerless agent still working 30 days after its creator leaves	Watch and end	6	guess matched	Confirmed
G06	Token stolen from an employee's personal AI agent still works 7 days later	Issue	6	guess matched	Partly confirmed
G07	Stolen session cookie still works an hour after MFA (continuous evaluation)	Watch and end	6	guess matched	Partly confirmed
G08	Decommissioned agent's certificate still accepted 7 days later (verify)	Watch and end	6	guess matched	Partly confirmed
G09	Secret copied from a build log still works 30 days later	Issue	6	guess matched	Partly confirmed
G10	Investigator cannot name the human who asked for an agent's action	Watch and end	6	guess matched	Confirmed
E04	Real cross-app agent access: revoke the user's grant and keep calling the second app	Watch and end	4	not run	not read yet
E05	Real admin agent handling a ticket that carries a reset instruction for another account	Act	4	not run	not read yet
E06	Real continuous access evaluation when a session is copied to another network	Watch and end	4	not run	not read yet

C

TERMS IN PLAIN WORDS

Glossary

Term	Meaning
AAL	Authenticator assurance level in NIST SP 800-63B. AAL3 needs a hardware-bound key that cannot be copied.
Access token	A short-lived credential an app presents to an API. Whoever holds it can usually use it.
AiTM	Adversary in the middle. A phishing proxy that relays the real sign-in and steals the session cookie after MFA.
Assertion	A signed statement from an identity provider that a user signed in, for example a SAML assertion.
Audience	The app or API a token or assertion is meant for. An app that does not check it may accept a token meant for another.
Authorization server	The service that issues OAuth tokens.
Break-glass account	An emergency account kept outside normal rules so admins are not locked out.
Conditional access	Rules that decide whether a sign-in is allowed, blocked or needs more proof, based on user, app, device and context.
Consent phishing	Tricking a user into granting a malicious app access, with no password stolen.
Continuous access evaluation	Re-checking a session after sign-in when something changes, such as a revoked user or a new network.
Cross App Access	An approach where an AI agent gets access to a second app through the enterprise identity provider.
Device code flow	An OAuth flow for devices without a keyboard. Attackers use it to get a victim to approve their code.
DPoP	Demonstrating Proof of Possession (RFC 9449). Binds a token to a key so a copied token fails from another machine.
Exclusion group	A group left out of a policy. It tends to grow.
Federation	Trusting another identity provider's sign-ins and claims.
FIDO2 and WebAuthn	Standards behind passkeys and security keys. The key signs only for the real site's origin.
Golden SAML	Forging SAML assertions with a stolen identity provider signing key.
Help desk reset	Staff resetting a password or MFA for a caller. A common way in for social engineers.
Identity provider (IdP)	The service that signs users in and vouches for them to apps.
Issuer	The identity provider or authorization server named in a token or metadata.
Legacy authentication	Old sign-in protocols, such as SMTP AUTH with a password, that cannot do MFA.
MCP	Model Context Protocol. A way for AI applications to connect to tools and data. Its authorization uses OAuth.
MFA, 2FA	Signing in with more than one kind of proof. 2FA means exactly two.
Nonce	A one-time value that ties a response to the request that asked for it.
Number matching	A push prompt where the user types a number shown on the sign-in screen, which stops blind approval.
OIDC	OpenID Connect. A sign-in layer on top of OAuth that issues ID tokens.

Term	Meaning
OAuth	A framework for granting apps limited access to resources with tokens.
On behalf of	An agent or service acting for a person. The token should carry who that person is.
Passkey	A FIDO credential that replaces a password. It can be synced across devices or bound to one.
Phishing-resistant MFA	MFA a look-alike site cannot relay, such as passkeys and security keys.
PKCE	Proof Key for Code Exchange. Stops an intercepted authorization code from being used by someone else.
Privileged access	Access that can change security settings, data or other people's access.
Push fatigue	Sending prompts until a tired user approves one.
Redirect URI	Where an authorization server sends the code or token. It must match exactly.
Refresh token	A longer-lived credential that gets new access tokens without signing in again.
Report-only mode	Running a policy that logs what it would do without enforcing it.
ROPC	Resource owner password credentials. Sending a password straight to the token endpoint, which cannot do MFA.
SAML	Security Assertion Markup Language. An older SSO standard based on signed XML assertions.
Service account	An account used by software, not a person.
Session	The period after sign-in when a cookie or token keeps a user signed in.
SIM swap	Moving a phone number to an attacker's SIM to receive SMS codes.
SSO	Single sign-on. One sign-in at the identity provider gives access to many apps.
Step-up	Asking for fresh, stronger proof before a sensitive action.
Sub-agent	An agent started by another agent to do part of a task.
Token binding	Tying a token to a device or key so it cannot be used elsewhere.
Token exchange	Swapping one token for another with narrower scope, for example when delegating (RFC 8693).
TOTP	Time-based one-time password from an authenticator app.
Trusted location	A network range a policy treats as safer, often to skip MFA.
Workload identity	An identity for software, such as a pipeline or a cloud function, that uses short-lived federated tokens.

STANDARDS, DOCUMENTS AND EVENTS

D Sources

Standards and documents

Document	Kind	What it says that matters here	Cases
RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPoP), September 2023 https://www.rfc-editor.org/rfc/rfc9449	Standard	Binds a token to a key so a copied token fails from another machine. Does not help against code inside the client.	W09 Y07
MCP authorization specification, 2026-07-28 revision https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization	Specification	Clients use protected resource metadata to find the authorization server, and check the issuer value on the response. The check gives no protection if the expected issuer came from an unvalidated source.	W11 Y11 Y12
Cloud Security Alliance, Defining Non-Human Identity, 22 July 2026 https://cloudsecurityalliance.org/artifacts/defining-non-human-identity	Industry research	Names six risk areas for all non-human identities, including missing owners, missing decommissioning triggers and access that grows through delegation. For agents it advises a human sponsor for each agent, sub-agents with minimal short-lived access limited to the human's own permissions, and logs that record the delegator, the agent and the intent.	G03 G04 G05 G10
GitHub Docs: OpenID Connect reference https://docs.github.com/en/actions/reference/security/oidc	Vendor documentation	At least one condition must be set on the cloud role so untrusted repositories cannot get tokens.	W01

Events

Date	Event	Links
6 Nov 2026	SonicWall SSLVPN: a user with valid credentials for another login method can bypass SAML, including SAML-enforced MFA (CVE-2026-19868). Applies only when SAML is on for VPN logins....	https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2026-0014 https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-19868 https://securityweek.com/sonicwall-patches-exploited-sonicos-bug-that-weakens-vpn-logins
28 Sep 2026	The official MCP Python SDK did not check the issuer on a fallback discovery path. A malicious MCP server could make an SDK-based client send its client secret, authorization code ...	https://labs.cloudsecurityalliance.org/research/csa-research-note-mcp-python-sdk-oauth-flaw-20260930-csa-sty/ https://thehackernews.com/2026/09/official-mcp-python-sdk-flaw-can-let.html
24 Aug 2026	Okta made Agent SSO generally available. It registers AI agents as identities, issues short-lived tokens in place of stored credentials, and moves agent authorization to the identi...	https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-sso/
15 Jul 2026	GitHub moves new repositories, and repositories that opt in, to an immutable subject claim in OIDC tokens. Cloud trust policies must include the numeric owner and repository IDs.	https://docs.github.com/en/actions/reference/security/oidc
Reported 17 Mar 2026	Researchers at NetSPI showed that certain nested app authentication flows could return Microsoft Graph tokens without Conditional Access being applied. They told Microsoft on 17 Ma...	https://www.netspi.com/blog/technical-blog/cloud-pentesting/bypassing-microsoft-entra-conditional-access-policies-via-nested-app-authentication/
27 Jan 2026	Microsoft revised the Exchange Online timeline for ending Basic authentication on SMTP AUTH (the path older printers and scanners use). It stays unchanged until December 2026, is t...	https://techcommunity.microsoft.com/blog/exchange/updated-exchange-online-smtp-auth-basic-authentication-deprecation-timeline/4489835
22 Jan 2026	Okta Threat Intelligence described phishing kits built for phone callers. The caller steers what the user sees in step with their script, which defeats any MFA that is not phishing...	https://www.okta.com/blog/threat-intelligence/phishing-kits-adapt-to-the-script-of-callers/
1 Oct 2025	Microsoft began enforcing MFA for Azure resource management at the Azure Resource Manager layer (Phase 2), for CLI, PowerShell, SDKs and REST calls. Tenants could postpone to 1 Jul...	https://learn.microsoft.com/entra/identity/authentication/concept-mandatory-multifactor-authentication https://azure.microsoft.com/blog/azure-mandatory-multifactor-authentication-phase-2-starting-in-october-2025/
8 to 20 Aug 2025	Stolen OAuth and refresh tokens from the Salesloft Drift integration were used to read data from many customers' Salesforce instances between 8 and 18 August. Salesloft and Salesfo...	https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift
9 Jul 2025	mcp-remote, a tool that connects AI clients to remote MCP servers, ran operating system commands from a crafted authorization endpoint sent by a malicious server (CVE-2025-6514, CV...	https://research.jfrog.com/vulnerabilities/mcp-remote-command-injection-rce-jfsa-2025-001290844/
14 to 18 Mar 2025	The GitHub Action tj-actions/changed-files was compromised and leaked CI/CD secrets through workflow logs (CVE-2025-30066). CISA added it to its Known Exploited Vulnerabilities lis...	https://www.cisa.gov/news-events/alerts/2025/03/18/supply-chain-compromise-third-party-github-action-cve-2025-30066
16 Nov 2023, updated 29 Jul 2025	CISA and the FBI described a group that phones IT help desks, poses as an employee and has the password reset and MFA moved to a device they control.	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a

Each catalogue row also has its own source, listed in the register on the website. Where I read only an excerpt or a summary, the register says so.

Run it yourself

Every guess file, script and result in this book is public. The scripts use only Python's standard library, check the guess file's hash before they run, and write the same results file on any machine. On 14 November 2026 they gave byte-identical results on a second computer.

If your product behaves differently from one of my models, report an exception. It goes next to my result, and my result stays.

roshantrivedi.co.in/ca-mfa-lab/

